



CyberScan
Security Audit Platform

8.8.8.8 — Procédure de Résolution des Vulnérabilités

Informations générales

Information	Valeur
Date et heure du scan	24/07/2026 à 15:07
Identifiant unique du scan	104
Client	chaima

NIVEAU DE RISQUE : FAIBLE
Score de risque IA : 2.5/10 — Score sécurité : 7.5/10

Le score sécurité est l'inverse du score de risque : plus il est bas, plus le niveau de vulnérabilité est élevé.

Document confidentiel — Usage interne uniquement

Sommaire

Informations générales	1
Situation actuelle	3
Fiches vulnérabilité	4
Plan de correction	7
Annexe CVE	7
Conclusion	7

Situation actuelle

L'audit de 8.8.8.8 a identifié 5 vulnérabilité(s) significative(s). OS/versions détectés : Country (UNITED STATES), HTTPServer (HTTP server (unknown), scaffolding on HTTPServer2), IP (8.8.8.8), RedirectLocation (https://dns.google/), Title (302 Moved, Google Public DNS), UncommonHeaders (x-content-type-options,access-control-allow-origin,alt-svc, content-security-policy,x-content-type-options,content-security-policy-report-only,cross-origin-opener-policy-report-only,report-to,alt-svc), X-Frame-Options (SAMEORIGIN), X-XSS-Protection (0), HTML5, Script, Strict-Transport-Security (max-age=31536000; includeSubDomains; preload).

■ 2. Méthodologie

SSLScan — Inventaire des protocoles et suites cryptographiques TLS.

Nmap — Détection des ports ouverts, services et bannières réseau.

OpenSSL — Contrôle de la négociation TLS et du certificat présenté.

WhatWeb — Identification des technologies et versions web.

OWASP ZAP — Analyse dynamique des contrôles de sécurité HTTP.

NVD — Corrélation des produits versionnés avec les CVE du NIST.

■ 3. Inventaire technique

Technologies détectées

Technologie	Version	Détails
Country	—	UNITED STATES
HTTPServer	—	HTTP server (unknown), scaffolding on HTTPServer2
IP	—	8.8.8.8
RedirectLocation	—	https://dns.google/
Title	—	302 Moved, Google Public DNS
UncommonHeaders	—	x-content-type-options,access-control-allow-origin,alt-svc, content-security-policy,x-content-type-options,content-security-policy-report-only,cross-origin-opener-policy-report-only,report-to,alt-svc
X-Frame-Options	—	SAMEORIGIN
X-XSS-Protection	—	0
HTML5	—	—
Script	—	—
Strict-Transport-Security	—	max-age=31536000; includeSubDomains; preload

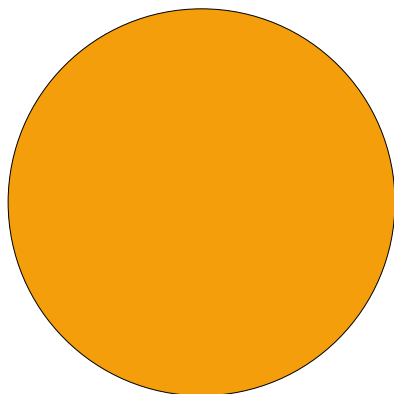
Ports exposés

Port	État	Service	Classification
443/tcp	open	https	Standard

■ 4. Indicateurs graphiques

Répartition des vulnérabilités par sévérité

Total : 5 vulnérabilité(s) significative(s)



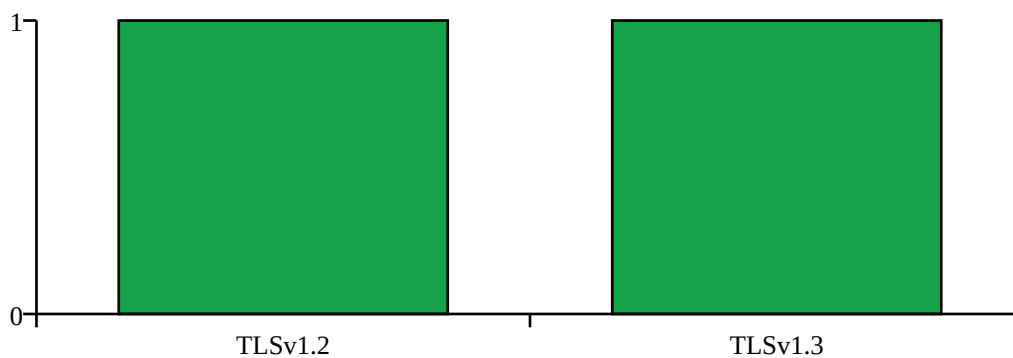
Moyen (5)

Jauge du score de risque IA



2.5/10

Statut des protocoles SSL/TLS



Fiches vulnérabilité

Vuln_001

Libellé	Valeur
Identifiant	Vuln_001
Composant vulnérable	CSP: Failure to Define Directive with No Fallback
Preuve d'audit	ZAP [Medium] CSP: Failure to Define Directive with No Fallback URL : https://8.8.8.8 Occurrences : 1
Type	Technique
Actif impacté	https://8.8.8.8

Libellé	Valeur
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Identifier dans le code ou la configuration la réponse signalée par ZAP.
2. Appliquer une correction ciblée en préproduction et ajouter un test de non-régression.
3. Rejouer ZAP sur l'URL concernée et archiver la preuve de correction.

Vuln_002

Libellé	Valeur
Identifiant	Vuln_002
Composant vulnérable	CSP: Wildcard Directive
Preuve d'audit	ZAP [Medium] CSP: Wildcard Directive URL : https://8.8.8.8 Occurrences : 1
Type	Technique
Actif impacté	https://8.8.8.8
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Identifier dans le code ou la configuration la réponse signalée par ZAP.
2. Appliquer une correction ciblée en préproduction et ajouter un test de non-régression.
3. Rejouer ZAP sur l'URL concernée et archiver la preuve de correction.

Vuln_003

Libellé	Valeur
Identifiant	Vuln_003
Composant vulnérable	CSP: script-src unsafe-eval
Preuve d'audit	ZAP [Medium] CSP: script-src unsafe-eval URL : https://8.8.8.8 Occurrences : 1

Libellé	Valeur
Type	Technique
Actif impacté	https://8.8.8.8
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Identifier dans le code ou la configuration la réponse signalée par ZAP.
2. Appliquer une correction ciblée en préproduction et ajouter un test de non-régression.
3. Rejouer ZAP sur l'URL concernée et archiver la preuve de correction.

Vuln_004

Libellé	Valeur
Identifiant	Vuln_004
Composant vulnérable	CSP: style-src unsafe-inline
Preuve d'audit	ZAP [Medium] CSP: style-src unsafe-inline URL : https://8.8.8.8 Occurrences : 1
Type	Technique
Actif impacté	https://8.8.8.8
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Identifier dans le code ou la configuration la réponse signalée par ZAP.
2. Appliquer une correction ciblée en préproduction et ajouter un test de non-régression.
3. Rejouer ZAP sur l'URL concernée et archiver la preuve de correction.

Vuln_005

Libellé	Valeur
Identifiant	Vuln_005
Composant vulnérable	Cross-Domain Misconfiguration

Libellé	Valeur
Preuve d'audit	ZAP [Medium] Cross-Domain Misconfiguration URL : https://8.8.8.8 Occurrences : 3
Type	Technique
Actif impacté	https://8.8.8.8
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Identifier dans le code ou la configuration la réponse signalée par ZAP.
2. Appliquer une correction ciblée en préproduction et ajouter un test de non-régression.
3. Rejouer ZAP sur l'URL concernée et archiver la preuve de correction.

Plan de correction

Priorité	Élément	Action corrective
P2	—	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
P2	—	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
P2	—	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
P2	—	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.
P2	—	Analyser le contrôle signalé par ZAP et corriger le composant concerné selon sa documentation de sécurité.

Annexe CVE

CVE / Élément	CVSS	Description
—	—	Aucune autre CVE pertinente après filtrage.

Conclusion

Le score sécurité est de 7.5/10, pour un risque faible (2.5/10). Appliquer les actions P1/P2 puis relancer CyberScan.

■ Annexe — sorties brutes complètes

SSLScan

```
Version: 2.1.5
OpenSSL 3.5.6 7 Apr 2026

Connected to 8.8.8.8

Testing SSL server 8.8.8.8 on port 443 using SNI name 8.8.8.8

SSL/TLS Protocols:
SSLv2 disabled
SSLv3 disabled
TLSv1.0 disabled
TLSv1.1 disabled
TLSv1.2 enabled
TLSv1.3 enabled

TLS Fallback SCSV:
Server supports TLS Fallback SCSV

TLS renegotiation:
Session renegotiation not supported

TLS Compression:
Compression disabled

Heartbleed:
TLSv1.3 not vulnerable to heartbleed
TLSv1.2 not vulnerable to heartbleed

Supported Server Cipher(s):
Preferred TLSv1.3 128 bits TLS_AES_128_GCM_SHA256
Accepted TLSv1.3 256 bits TLS_AES_256_GCM_SHA384
Accepted TLSv1.3 256 bits TLS_CHACHA20_POLY1305_SHA256
Preferred TLSv1.2 256 bits ECDHE-RSA-CHACHA20-POLY1305 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-GCM-SHA384 Curve 25519 DHE 253

Server Key Exchange Group(s):
TLSv1.3 128 bits secp256r1 (NIST P-256)
TLSv1.3 128 bits x25519
TLSv1.2 128 bits secp256r1 (NIST P-256)
TLSv1.2 128 bits x25519

SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption
RSA Key Strength: 2048

Subject: dns.google
AltNames: DNS:dns.google, DNS:dns.google.com, DNS:*.dns.google.com, DNS:8888.google, DNS:dns64.dns.google, IP
Address:8.8.8.8, IP Address:8.8.4.4, IP Address:8.8.8.53, IP Address:2001:4860:4860:0:0:0:0:8888, IP
Address:2001:4860:4860:0:0:0:0:8844, IP Address:2001:4860:4860:0:0:0:0:6464, IP
Address:2001:4860:4860:0:0:0:0:64
Issuer: WR2

Not valid before: Jun 29 08:40:15 2026 GMT
Not valid after: Sep 21 08:40:14 2026 GMT
```

Nmap

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-24 16:04 CET
Nmap scan report for dns.google (8.8.8.8)
Host is up (0.062s latency).

PORT STATE SERVICE
443/tcp open https
| ssl-enum-ciphers:
| TLSv1.2:
| ciphers:
```



```
| TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (ecd_h_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (ecd_h_x25519) - A
| TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (ecd_h_x25519) - A
| compressors:
| NULL
| cipher preference: client
| TLSv1.3:
| ciphers:
| TLS_AKE_WITH_AES_128_GCM_SHA256 (ecd_h_x25519) - A
| TLS_AKE_WITH_AES_256_GCM_SHA384 (ecd_h_x25519) - A
| TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecd_h_x25519) - A
| cipher preference: client
|_ least strength: A
```

Nmap done: 1 IP address (1 host up) scanned in 2.32 seconds

OpenSSL

```
Connecting to 8.8.8.8
depth=2 C=US, O=Google Trust Services LLC, CN=GTS Root R1
verify return:1
depth=1 C=US, O=Google Trust Services, CN=WR2
verify return:1
depth=0 CN=dns.google
verify return:1
CONNECTED(00000003)
---
Certificate chain
0 s:CN=dns.google
i:C=US, O=Google Trust Services, CN=WR2
a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Jun 29 08:40:15 2026 GMT; NotAfter: Sep 21 08:40:14 2026 GMT
1 s:C=US, O=Google Trust Services, CN=WR2
i:C=US, O=Google Trust Services LLC, CN=GTS Root R1
a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Dec 13 09:00:00 2023 GMT; NotAfter: Feb 20 14:00:00 2029 GMT
2 s:C=US, O=Google Trust Services LLC, CN=GTS Root R1
i:C=BE, O=GlobalSign nv-sa, OU=Root CA, CN=GlobalSign Root CA
a:PKEY: RSA, 4096 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Jun 19 00:00:42 2020 GMT; NotAfter: Jan 28 00:00:42 2028 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIFtzCCBJ+gAwIBAgIQcwMbiDaZf2QJ+897kcmGxTANBgkqhkiG9w0BAQsFADA7
MQswCQYDVQQGEwJVUzEeMBwGA1UEChMVVR29vZ2x1LlFRydXN0IFNlcnZpY2VzMQww
CgYDVQQDEwNXUjIwHhcNMjYwNjI5MDg0MDE1WhcNMjYwOTIxMDg0MDEwWjAVMRMw
EQYDVQQDEwphbnMuZ29vZ2x1LmIiBjIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKC
AQEAX/MFdsXCPD1x0UwcnjQo6CohARuvxr0igP0f+wiCsI+B0a59f0CjNeDyE2Z7
YIn8tem6ArDRcgZeJLr2LY80UL8jrrTRvIrrqCgMYLWT4Juqpp4pkPMeBnJyY8hkB
gBR+sUg8KmpAs94WfVIIeqnkZmH80HtLh20bAin4ky1y2GnuBVFfS0cVv01d0i7n
2RHpt72d/nGthEzu7YLSHkVTVgAB034oLJ6aNeUfm1KFZ8qEr0871A1+JQ5P+Ob
/Zqtt+bD/OCakQg1KmusZZLT0/s4rTdNWTic0QTe6YBhJsUc5i06TWPP0tiENGc
Sju5qFKgVudEYds8l61Y0BV0fwIDAQABo4IC2zCCAtcwDgYDVROPAQH/BAQDAgWg
```

```
MBMGA1UdJQMMAoGCCSGAUFBwMBMAwGA1UdEwEB/wQCMAAwHQYDVROBBYEFJRl
KN1Fm9YTQ2jvqB4oNoomF0vMB8GA1UdIwQYMBaAFN4bHu15FdQ+NyTDIbvsNDlt
QrIwMFgGCCSGAUFBwEBBewwSjAhBggrBgEFBQcwAYYVaHR0cDovL28ucGtpLmdv
b2c2vd3IyMCUGCCSGAUFBzACHh1odHRwOi8vaS5wa2kuZ29vZy93cjIuY3J0MIGY
BgNVHREEGaowgaeCCMRucy5nb29nbGwCdMRucy5nb29nbGUuY29tghAqLmRucy5n
b29nbGUuY29tggs40Dg4Lmdvb2dsZYIqZG5zNjQuZG5zLmdvb2dsZYcECAGICiE
CAGEBICeCAGINycQIAFIYEHgAAAAAAAAAACIIiCQIAFIYEHgAAAAAAAAAACIRIcQ
IAFIYEHgAAAAAAAAABkZiCQIAFIYEHgAAAAAAAAAAZDATBgNVHSAEDDAKMAGG
BmeBDAECATA2BgNVHR8ELZAtMCugKaAnhiVodHRwOi8vYy5wa2kuZ29vZy93cjIv
R1N5VDFOFBCmcuY3JsMIIBBAYKKwYBBAHWeQIEAgSB9QSB8gDwAHYA2AlV05RP
ev/IFhlvLE+Fq7D4/F6HVSYPFdEucrtFSxQAAAGfESBAWQAABAMARzBFAiBHZrEw
XDuEx58wUw0/mKxpe82B8LzrkYX8T/ib+3LSxQIhAMB0KCxBeyP9q3G0exxQ4xMT
963lVZY5V3sj0zMIDe6AHYAwjF+V0UZo0XufzjespBB68fCIVoiv3/Vta12mtk0
Us0AAAGfESBAwQAABAMARzBFAiA2CSyRzAmRu4P4VyoPtDdl3L07CZJvq4THEacB
eP0dYAIhAJmLnJ8maKktHa+JFu4gOwQ/sZvfwSdLDeKcdiUJWfZMA0GCSqGSIb3
DQEBwUAA4IBAQBNDTCx3JzJwi137vbyTEq/qVvyVrwd47k7VgFhCLaCATPV+Y/S
pKvRqPMkx11Fg3SR4dXPMAv0RHun2mC9NcbDMRCWFE2iNNx3Aewy2AUqi5LB1Jd9
7P2IremrZe949V8o50SxolXpbBtXwG/l1pI8GaW/BvlyAnyo+9MAKKH+5k6wQhP
9FXs05+8mXT9NYRcECvhd5p57L4hlRhGJcdzeguoAKEDEoZUSdFY0Zt2K7vxrUpL
```

```
jRvmfGbQEa3FN7CYM0ePmspbgsKysJPQ240XEE66CpcTUbki4YuaDQPutgPDhrmc
LMvz9AkGtieEkaRMMd2T91JJb04jSgxrauwy
-----END CERTIFICATE-----
subject=CN=dns.google
issuer=C=US, O=Google Trust Services, CN=WR2
---
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: rsa_pss_rsae_sha256
Negotiated TLS1.3 group: X25519MLKEM768
---
SSL handshake has read 5732 bytes and written 1629 bytes
Verification: OK
---
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Protocol: TLSv1.3
```

```
Server public key is 2048 bit
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---
DONE
```

WhatWeb

```
{
  "success": true,
  "technologies": [
    {
      "name": "Country",
      "version": [],
      "string": [
        "UNITED STATES"
      ]
    },
    {
      "name": "HTTPServer",
      "version": [],
      "string": [
        "HTTP server (unknown)",
        "scaffolding on HTTPServer2"
      ]
    },
    {
      "name": "IP",
      "version": [],
      "string": [
        "8.8.8.8"
      ]
    },
    {
      "name": "RedirectLocation",
      "version": [],
      "string": [
        "https://dns.google/"
      ]
    },
    {
      "name": "Title",
      "version": [],
      "string": [
        "302 Moved",
        "Google Public DNS"
      ]
    },
    {
      "name": "UncommonHeaders",
      "version": [],
```

```

"string": [
"x-content-type-options,access-control-allow-origin,alt-svc",
"content-security-policy,x-content-type-options,content-security-policy-report-only,cross-origin-opener-policy-report-only,report-to,alt-svc"
],
},
{
"name": "X-Frame-Options",
"version": [],
"string": [
"SAMEORIGIN"
]
},
{
"name": "X-XSS-Protection",
"version": [],
"string": [
"0"
]
},
{
"name": "HTML5",
"version": [],
"string": []
},
{
"name": "Script",
"version": [],
"string": []
},
{
"name": "Strict-Transport-Security",
"version": [],
"string": [
"max-age=31536000; includeSubDomains; preload"
]
}
]
}

```

OWASP ZAP

```

{
"@programName": "ZAP",
"@version": "2.17.0",
"@generated": "Fri, 24 Jul 2026 15:07:26",
"@created": "2026-07-24T15:07:26.282121299Z",
"insights":[
{
"level": "Info",
"reason": "Informational",
"site": "https://8.8.8.8",
"key": "insight.code.2xx",
"description": "Percentage of responses with status code 2xx",
"statistic": "25"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://8.8.8.8",
"key": "insight.code.3xx",
"description": "Percentage of responses with status code 3xx",
"statistic": "75"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://8.8.8.8",
"key": "insight.endpoint ctype.text/html",
"description": "Percentage of endpoints with content type text/html",
"statistic": "100"
},

```

```

{
  "level": "Info",
  "reason": "Informational",
  "site": "https://8.8.8.8",
  "key": "insight.endpoint.method.GET",

  "description": "Percentage of endpoints with method GET",
  "statistic": "100"
},
{
  "level": "Info",
  "reason": "Informational",
  "site": "https://8.8.8.8",
  "key": "insight.endpoint.total",
  "description": "Count of total endpoints",
  "statistic": "2"
},
{
  "level": "Info",
  "reason": "Informational",
  "site": "https://8.8.8.8",
  "key": "insight.response.slow",
  "description": "Percentage of slow responses",
  "statistic": "75"
}
],
"site": [
  {
    "@name": "https://8.8.8.8",
    "@host": "8.8.8.8",
    "@port": "443",
    "@ssl": "true",
    "alerts": [
      {
        "pluginid": "10055",
        "alertRef": "10055-13",
        "alert": "CSP: Failure to Define Directive with No Fallback",
        "name": "CSP: Failure to Define Directive with No Fallback",
        "riskcode": "2",
        "confidence": "3",
        "riskdesc": "Medium (High)",

        "desc": "<p>The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.</p>",
        "instances": [
          {
            "id": "11",
            "uri": "https://8.8.8.8",
            "nodeName": "https:\\\\8.8.8.8",
            "method": "GET",
            "param": "Content-Security-Policy",
            "attack": "",
            "evidence": "object-src 'none';base-uri 'self';script-src 'nonce-f9X_FtY7wAUr8DeYzQlbIw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/honest_dns/1_0;frame-ancestors 'none'",
            "otherinfo": "The directive(s): form-action is/are among the directives that do not fallback to default-src."
          }
        ],
        "count": "1",
        "systemic": false,
        "solution": "<p>Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.</p>",
        "otherinfo": "<p>The directive(s): form-action is/are among the directives that do not fallback to default-src.</p>",
        "reference": "<p>https://www.w3.org/TR/CSP/</p><p>https://caniuse.com/#search=content+security+policy</p><p>https://content-security-policy.com/</p><p>https://github.com/HtmlUnit/htmlunit-csp</p><p>https://web.dev/articles/csp#resource-options</p>",
        "cweid": "693",
        "wascid": "15",
        "sourceid": "1"
      }
    ]
  }
],
{
  "pluginid": "10055",
  "alertRef": "10055-4",

```

```

"alert": "CSP: Wildcard Directive",
"name": "CSP: Wildcard Directive",
"riskcode": "2",
"confidence": "3",
"riskdesc": "Medium (High)",
"desc": "<p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
"instances":[
{
"id": "12",
"uri": "https://8.8.8.8",

"nodeName": "https://8.8.8.8",
"method": "GET",
"param": "Content-Security-Policy",
"attack": "",
"evidence": "object-src 'none';base-uri 'self';script-src 'nonce-f9X_FtY7wAUr8DeYzQlbIw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/honest_dns/1_0;frame-ancestors 'none'",
"otherinfo": "The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:\nstyle-src, img-src, connect-src, frame-src, font-src, media-src, manifest-src, worker-src"
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.</p>",
"otherinfo": "<p>The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:</p><p>style-src, img-src, connect-src, frame-src, font-src, media-src, manifest-src, worker-src</p>",
"reference": "<p>https://www.w3.org/TR/CSP/</p><p>https://caniuse.com/#search=content+security+policy</p><p>https://content-security-policy.com/</p><p>https://github.com/HtmlUnit/htmlunit-csp</p><p>https://web.dev/articles/csp#resource-options</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "10055",
>alertRef": "10055-10",
>alert": "CSP: script-src unsafe-eval",
"name": "CSP: script-src unsafe-eval",
"riskcode": "2",
"confidence": "3",
"riskdesc": "Medium (High)",
"desc": "<p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
"instances":[
{
"id": "14",
"uri": "https://8.8.8.8",
"nodeName": "https://8.8.8.8",
"method": "GET",
"param": "Content-Security-Policy",
"attack": "",
"evidence": "object-src 'none';base-uri 'self';script-src 'nonce-f9X_FtY7wAUr8DeYzQlbIw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/honest_dns/1_0;frame-ancestors 'none'",

"otherinfo": "script-src includes unsafe-eval."
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is properly configured

```

```
to set the Content-Security-Policy header.</p>",
"otherinfo": "<p>script-src includes unsafe-eval.</p>",
"reference": "<p>https://www.w3.org/TR/CSP/</p><p>https://caniuse.com/#search=content+security+policy</p><p>https://content-security-policy.com/</p><p>https://github.com/HtmlUnit/htmlunit-csp</p><p>https://web.dev/articles/csp#resource-options</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
  "pluginid": "10055",
  "alertRef": "10055-6",
  "alert": "CSP: style-src unsafe-inline",
  "name": "CSP: style-src unsafe-inline",
  "riskcode": "2",
  "confidence": "3",
  "riskdesc": "Medium (High)",
  "desc": "<p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
  "instances": [
    {
      "id": "13",
      "uri": "https://8.8.8.8",
      "nodeName": "https:\\\\8.8.8.8",
      "method": "GET",
      "param": "Content-Security-Policy",
      "attack": "",
      "evidence": "object-src 'none';base-uri 'self';script-src 'nonce-f9X_FtY7wAUr8DeYzQlbIw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/honest_dns/1_0;frame-ancestors 'none'",
      "otherinfo": "style-src includes unsafe-inline."
    }
  ],
  "count": "1",
  "systemic": false,
```

```
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.</p>",
"otherinfo": "<p>style-src includes unsafe-inline.</p>",
"reference": "<p>https://www.w3.org/TR/CSP/</p><p>https://caniuse.com/#search=content+security+policy</p><p>https://content-security-policy.com/</p><p>https://github.com/HtmlUnit/htmlunit-csp</p><p>https://web.dev/articles/csp#resource-options</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
  "pluginid": "10098",
  "alertRef": "10098",
  "alert": "Cross-Domain Misconfiguration",
  "name": "Cross-Domain Misconfiguration",
  "riskcode": "2",
  "confidence": "2",
  "riskdesc": "Medium (Medium)",
  "desc": "<p>Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.</p>",
  "instances": [
    {
      "id": "5",
      "uri": "https://8.8.8.8",
      "nodeName": "https:\\\\8.8.8.8",
      "method": "GET",
      "param": "",
      "attack": "",
      "evidence": "Access-Control-Allow-Origin: *",
      "otherinfo": "The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing."
    }
  ],
```

```

{
  "id": "21",
  "uri": "https://8.8.8.8/robots.txt",
  "nodeName": "https:\\\\8.8.8.8\\robots.txt",
  "method": "GET",
  "param": "",
  "attack": "",
  "evidence": "Access-Control-Allow-Origin: *",

  "otherinfo": "The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing."
},
{
  "id": "18",
  "uri": "https://8.8.8.8/sitemap.xml",
  "nodeName": "https:\\\\8.8.8.8\\sitemap.xml",
  "method": "GET",
  "param": "",
  "attack": "",
  "evidence": "Access-Control-Allow-Origin: *",
  "otherinfo": "The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing."
},
],
"count": "3",
"systemic": false,
"solution": "<p>Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).</p><p>Configure the \"Access-Control-Allow-Origin\" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.</p>",
"otherinfo": "<p>The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.</p>",
"reference": "<p>https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy</p>",
"cweid": "264",
"wascid": "14",
"sourceid": "6"
},
{
  "pluginid": "10055",
  "alertRef": "10055-3",
  "alert": "CSP: Notices",
  "name": "CSP: Notices",
  "riskcode": "1",
  "confidence": "3",
  "riskdesc": "Low (High)",
  "desc": "<p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
  "instances": [
    {
      "id": "10",
      "uri": "https://8.8.8.8",

      "nodeName": "https:\\\\8.8.8.8",
      "method": "GET",
      "param": "Content-Security-Policy",
      "attack": "",
      "evidence": "object-src 'none';base-uri 'self';script-src 'nonce-f9X_FtY7wAUr8DeYzQ1bIw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/honest_dns/1_0;frame-ancestors 'none'",
      "otherinfo": "Warnings:\\nThe report-uri directive has been deprecated in favor of the new report-to

```

```

directive\n"
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.</p>",
"otherinfo": "<p>Warnings:</p><p>The report-uri directive has been deprecated in favor of the new report-to directive</p><p></p>",
"reference": "<p>https://www.w3.org/TR/CSP/</p><p>https://caniuse.com/#search=content+security+policy</p><p>https://content-security-policy.com/</p><p>https://github.com/HtmlUnit/htmlunit-csp</p><p>https://web.dev/articles/csp#resource-options</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "90004",
>alertRef": "90004-2",
>alert": "Cross-Origin-Embedder-Policy Header Missing or Invalid",
"name": "Cross-Origin-Embedder-Policy Header Missing or Invalid",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).</p>",
"instances": [
{
"id": "4",
"uri": "https://8.8.8.8",
"nodeName": "https://8.8.8.8",
"method": "GET",
"param": "Cross-Origin-Embedder-Policy",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents.</p><p>If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).</p>",
"otherinfo": "",
"reference": "<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy</p>",
"cweid": "693",
"wascid": "14",
"sourceid": "1"
},
{
"pluginid": "90004",
>alertRef": "90004-3",
>alert": "Cross-Origin-Opener-Policy Header Missing or Invalid",
"name": "Cross-Origin-Opener-Policy Header Missing or Invalid",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.</p>",
"instances": [
{
"id": "6",
"uri": "https://8.8.8.8",
"nodeName": "https://8.8.8.8",
"method": "GET",
"param": "Cross-Origin-Opener-Policy",
"attack": "",
"evidence": "",
"otherinfo": ""
}
]
}

```



```

],
"count": "1",
"systemic": false,

"solution": "<p>Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents.</p><p>'same-origin-allow-popups' is considered as less secured and should be avoided.</p><p>If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http\_headers\_cross-origin-opener-policy).</p>\"",
"otherinfo": "",
"reference": "<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy</p>",
"cweid": "693",
"wascid": "14",
"sourceid": "1"
},
{
"pluginid": "90004",
>alertRef": "90004-1",
>alert": "Cross-Origin-Resource-Policy Header Missing or Invalid",
"name": "Cross-Origin-Resource-Policy Header Missing or Invalid",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.</p>",
"instances": [
{
"id": "3",
"uri": "https://8.8.8.8",
"nodeName": "https:\\\\8.8.8.8",
"method": "GET",
"param": "Cross-Origin-Resource-Policy",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages.</p><p>'same-site' is considered as less secured and should be avoided.</p><p>If resources must be shared, set the header to 'cross-origin'.</p><p>If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http\_headers\_cross-origin-resource-policy).</p>",
"otherinfo": "",
"reference": "<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy</p>",
"cweid": "693",
"wascid": "14",

"sourceid": "1"
},
{
"pluginid": "10063",
>alertRef": "10063-1",
>alert": "Permissions Policy Header Not Set",
"name": "Permissions Policy Header Not Set",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.</p>",
"instances": [
{
"id": "2",
"uri": "https://8.8.8.8",
"nodeName": "https:\\\\8.8.8.8",
"method": "GET",
"param": "",

```

```

"attack": "",
"evidence": "",
"otherinfo": ""
},
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.</p>",
"otherinfo": "",
"reference": "<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy</p><p>https://developer.chrome.com/blog/feature-policy/</p><p>https://scotthelme.co.uk/a-new-security-header-feature-policy/</p><p>https://w3c.github.io/webappsec-feature-policy/</p><p>https://www.smashingmagazine.com/2018/12/feature-policy/</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "10036",
>alertRef": "10036-2",

```

```

>alert": "Server Leaks Version Information via \"Server\" HTTP Response Header Field",
"name": "Server Leaks Version Information via \"Server\" HTTP Response Header Field",
"riskcode": "1",
"confidence": "3",
"riskdesc": "Low (High)",
"desc": "<p>The web/application server is leaking version information via the \"Server\" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.</p>",
"instances":[
{
"id": "16",
"uri": "https://8.8.8.8",
"nodeName": "https://8.8.8.8",
"method": "GET",
"param": "",
"attack": "",
"evidence": "scaffolding on HTTPServer2",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to suppress the \"Server\" header or provide generic details.</p>",
"otherinfo": "",
"reference": "<p>https://httpd.apache.org/docs/current/mod/core.html#servertokens</p><p>https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)</p><p>https://www.troyhunt.com/shhh-dont-let-your-response-headers/</p>",
"cweid": "497",
"wascid": "13",
"sourceid": "1"
},
{
"pluginid": "10035",
>alertRef": "10035-1",
>alert": "Strict-Transport-Security Header Not Set",
"name": "Strict-Transport-Security Header Not Set",
"riskcode": "1",
"confidence": "3",
"riskdesc": "Low (High)",

```

```

"desc": "<p>HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.</p>",
"instances":[
{
"id": "9",
"uri": "https://8.8.8.8",
"nodeName": "https://8.8.8.8",
"method": "GET",
"param": "",

```

```

"attack": "",
"evidence": "",
"otherinfo": ""
},
{
  "id": "22",
  "uri": "https://8.8.8.8/robots.txt",
  "nodeName": "https:\\\\8.8.8.8\\robots.txt",
  "method": "GET",
  "param": "",
  "attack": "",
  "evidence": "",
  "otherinfo": ""
},
{
  "id": "19",
  "uri": "https://8.8.8.8/sitemap.xml",
  "nodeName": "https:\\\\8.8.8.8\\sitemap.xml",
  "method": "GET",
  "param": "",
  "attack": "",
  "evidence": "",
  "otherinfo": ""
}
],
"count": "3",
"systemic": false,

```

"solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.</p>",

"otherinfo": "",
 "reference": "<p>[https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html](\"https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html\")</p><p>[https://owasp.org/www-community/Security-Headers](\"https://owasp.org/www-community/Security-Headers\")</p><p>[https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security](\"https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security\")</p><p>[https://caniuse.com/stricttransportsecurity](\"https://caniuse.com/stricttransportsecurity\")</p><p>[https://datatracker.ietf.org/doc/html/rfc6797](\"https://datatracker.ietf.org/doc/html/rfc6797\")</p></p>",
 "cweid": "319",
 "wascid": "15",
 "sourceid": "6"

```

},
{
  "pluginid": "10038",
  "alertRef": "10038-3",
  "alert": "Content Security Policy (CSP) Report-Only Header Found",
  "name": "Content Security Policy (CSP) Report-Only Header Found",
  "riskcode": "0",
  "confidence": "3",
  "riskdesc": "Informational (High)",
  "desc": "<p>The response contained a Content-Security-Policy-Report-Only header, this may indicate a work-in-progress implementation, or an oversight in promoting pre-Prod to Prod, etc.</p><p></p><p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
  "instances":[
    {
      "id": "8",
      "uri": "https://8.8.8.8",
      "nodeName": "https:\\\\8.8.8.8",
      "method": "GET",
      "param": "",
      "attack": "",
      "evidence": "",
      "otherinfo": ""
    }
  ],
  "count": "1",
  "systemic": false,
  "solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.</p>",
  "otherinfo": "",
  "reference": "<p>https://www.w3.org/TR/CSP2/</p><p>https://w3c.github.io/webappsec-csp/</p><p>https://caniuse.com/#feat=contentsecuritypolicy</p><p>https://content-security-policy.com/</p></p>",

```

```
"cweid": "693",
"wascid": "15",
```

```
"sourceid": "1"
},
{
  "pluginid": "10049",
  "alertRef": "10049-1",
  "alert": "Non-Storable Content",
  "name": "Non-Storable Content",
  "riskcode": "0",
  "confidence": "2",
  "riskdesc": "Informational (Medium)",
  "desc": "<p>The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.</p>",
  "instances": [
    {
      "id": "0",
      "uri": "https://8.8.8.8",
      "nodeName": "https:\\\\8.8.8.8",
      "method": "GET",
      "param": "",
      "attack": "",
      "evidence": "302",
      "otherinfo": ""
    },
    {
      "id": "20",
      "uri": "https://8.8.8.8/robots.txt",
      "nodeName": "https:\\\\8.8.8.8\\robots.txt",
      "method": "GET",
      "param": "",
      "attack": "",
      "evidence": "302",
      "otherinfo": ""
    },
    {
      "id": "17",
      "uri": "https://8.8.8.8/sitemap.xml",
      "nodeName": "https:\\\\8.8.8.8\\sitemap.xml",
      "method": "GET",
      "param": "",
      "attack": "",
      "evidence": "302",
      "otherinfo": ""
    }
  ],
  "count": "3",
  "systemic": false,
  "solution": "<p>The content may be marked as storable by ensuring that the following conditions are satisfied:</p><p>The request method must be understood by the cache and defined as being cacheable (\\\"GET\\\", \\\"HEAD\\\", and \\\"POST\\\" are currently defined as cacheable)</p><p>The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood)</p><p>The \\\"no-store\\\" cache directive must not appear in the request or response header fields</p><p>For caching by \\\"shared\\\" caches such as \\\"proxy\\\" caches, the \\\"private\\\" response directive must not appear in the response</p><p>For caching by \\\"shared\\\" caches such as \\\"proxy\\\" caches, the \\\"Authorization\\\" header field must not appear in the request, unless the response explicitly allows it (using one of the \\\"must-revalidate\\\", \\\"public\\\", or \\\"s-maxage\\\" Cache-Control response directives)</p><p>In addition to the conditions above, at least one of the following conditions must also be satisfied by the response:</p><p>It must contain an \\\"Expires\\\" header field</p><p>It must contain a \\\"max-age\\\" response directive</p><p>For \\\"shared\\\" caches such as \\\"proxy\\\" caches, it must contain a \\\"s-maxage\\\" response directive</p><p>It must contain a \\\"Cache Control Extension\\\" that allows it to be cached</p><p>It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).</p>",
  "otherinfo": "",
  "reference": "<p>https://datatracker.ietf.org/doc/html/rfc7234</p><p>https://datatracker.ietf.org/doc/html/rfc7231</p><p>https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html</p>",
  "cweid": "524",
  "wascid": "13",
  "sourceid": "6"
},
{
  "pluginid": "10015",
```

```

"alertRef": "10015",
"alert": "Re-examine Cache-control Directives",
"name": "Re-examine Cache-control Directives",
"riskcode": "0",
"confidence": "1",
"riskdesc": "Informational (Low)",
"desc": "<p>The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.</p>",
"instances": [
{
"id": "7",
"uri": "https://8.8.8.8",
"nodeName": "https:\\\\8.8.8.8",
"method": "GET",
"param": "cache-control",
"attack": "",
"evidence": "public, max-age=300",

"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>For secure content, ensure the cache-control HTTP header is set with \\\"no-cache, no-store, must-revalidate\\\". If an asset should be cached consider setting the directives \\\"public, max-age, immutable\\\".</p>",
"otherinfo": "",
"reference": "<p>https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching</p><p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control</p><p>https://grayduck.mn/2021/09/13/cache-control-recommendations/</p>",
"cweid": "525",
"wascid": "13",
"sourceid": "1"
},
{
"pluginid": "10050",
"alertRef": "10050-2",
"alert": "Retrieved from Cache",
"name": "Retrieved from Cache",
"riskcode": "0",
"confidence": "2",
"riskdesc": "Informational (Medium)",
"desc": "<p>The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as \\\"proxy\\\" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.</p>",
"instances": [
{
"id": "15",
"uri": "https://8.8.8.8",
"nodeName": "https:\\\\8.8.8.8",
"method": "GET",
"param": "",
"attack": "",
"evidence": "Age: 233",
"otherinfo": "The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use."
}
],
"count": "1",
"systemic": false,

"solution": "<p>Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:</p><p>Cache-Control: no-cache, no-store, must-revalidate, private</p><p>Pragma: no-cache</p><p>Expires: 0</p><p>This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.</p>",
"otherinfo": "<p>The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.</p>",
"reference": "<p>https://datatracker.ietf.org/doc/html/rfc7234</p><p>https://datatracker.ietf.org/doc/html/rfc7231</p><p>https://www.rfc-editor.org/rfc/rfc9110.html</p>",

```

```

"cwecid": "525",
"wasccid": "-1",
"sourceid": "1"
},
{
  "pluginid": "10049",
  "alertRef": "10049-3",
  "alert": "Storable and Cacheable Content",
  "name": "Storable and Cacheable Content",
  "riskcode": "0",
  "confidence": "2",
  "riskdesc": "Informational (Medium)",
  "desc": "<p>The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where \"shared\" caching servers such as \"proxy\" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.</p>",
  "instances": [
    {
      "id": "1",
      "uri": "https://8.8.8.8",
      "nodeName": "https://8.8.8.8",
      "method": "GET",
      "param": "",
      "attack": "",
      "evidence": "max-age=300",
      "otherinfo": ""
    }
  ],
  "count": "1",
  "systemic": false,
  "solution": "<p>Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:</p><p>Cache-Control: no-cache, no-store, must-revalidate, private</p><p>Pragma: no-cache</p><p>Expires: 0</p><p>This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.</p>",
  "otherinfo": "",
  "reference": "<p>https://datatracker.ietf.org/doc/html/rfc7234</p><p>https://datatracker.ietf.org/doc/html/rfc7231</p><p>https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html</p>",
  "cwecid": "524",
  "wasccid": "13",
  "sourceid": "1"
}
],
"sequences": [
]
}

```

NVD

Aucune sortie brute disponible.

Preuves techniques complètes disponibles en export JSON depuis l'historique des scans (scan ID : 104)